UNIVERSIDAD POLITÉCNICA DE SAN LUIS POTOSÍ

INGENIERÍA EN TECNOLOGÍAS DE LA INFORMACIÓN

Universidad Politécnica de San Luis Potosí
Ingeniería en Tecnologías de la Información
CNO V: Seguridad Informática
Primavera 2026

PR02 – El eslabón más débil: Diseño de una campaña de ingeniería social.

Investigación comparativa de plataforma.

Alumno: Jorge Emmanuel López Monsiváis 179842
Profesor: Servando López Contreras

Fecha de Entrega: 06/03/2026

Introducción

El phishing constituye uno de los vectores de ataque más explotados dentro de la ingeniería social moderna. Diversos informes de ciberseguridad coinciden en que el factor humano sigue siendo el eslabón más vulnerable en la cadena de seguridad organizacional. En este contexto, las plataformas de simulación de phishing emergen como herramientas estratégicas dentro del modelo de defensa en profundidad y del enfoque Zero Trust. Desde una perspectiva técnica, estas soluciones permiten ejecutar campañas controladas que replican escenarios reales de ataque, con el fin de medir indicadores como tasa de clic, tasa de reporte, tiempo de reacción y nivel de riesgo por departamento. Su integración con directorios corporativos, sistemas SIEM y soluciones de correo seguro permite una gestión centralizada y basada en métricas.

No obstante, su implementación plantea desafíos éticos y organizacionales. Una simulación mal gestionada puede generar desconfianza laboral o prácticas punitivas. Por ello, el enfoque adecuado debe priorizar la cultura de aprendizaje continuo, anonimización de resultados y transparencia institucional. El presente documento desarrolla un análisis comparativo con enfoque crítico técnico y ético de ocho plataformas líderes del mercado.

La transformación digital y la creciente sofisticación de las amenazas cibernéticas han evidenciado que el factor humano constituye uno de los principales vectores de riesgo dentro de las organizaciones. Diversos marcos de referencia internacionales, como NIST e ISO/IEC 27001, establecen que la concienciación y capacitación en seguridad forman parte esencial de los controles organizacionales para la gestión del riesgo. En este contexto, las plataformas de simulación de phishing y capacitación en seguridad surgen como herramientas especializadas orientadas a fortalecer la resiliencia humana frente a ataques de ingeniería social.

Estas plataformas no solo permiten ejecutar campañas controladas que simulan escenarios reales de ataque (como correos fraudulentos, suplantación de identidad o robo de credenciales), sino que integran funcionalidades avanzadas como análisis conductual, métricas de susceptibilidad, segmentación por perfiles de riesgo e integración con infraestructuras empresariales (SIEM, SOC, directorios corporativos y soluciones de correo seguro). Desde una perspectiva técnica, su valor radica en convertir el comportamiento del usuario en un indicador medible dentro del sistema de gestión de seguridad de la información.

Asimismo, la evolución de estas herramientas ha incorporado inteligencia adaptativa, aprendizaje basado en comportamiento y mecanismos de gamificación, con el objetivo de aumentar la efectividad formativa y reducir la repetición de errores. Algunas soluciones priorizan la integración profunda con ecosistemas corporativos de seguridad, mientras que otras enfatizan el componente pedagógico, cultural y narrativo como medio para modificar hábitos organizacionales. Vamos a conocer un poco mas de estas plataformas:

Fichas Descriptivas

Hoxhunt

Modelo Tecnológico	Aprendizaje adaptativo con IA y gamificación conductual.
Tipo de Simulación	Phishing dinámico personalizado en tiempo real.
Integraciones	Microsoft 365, Google Workspace, APIs empresariales.
Métricas	Riesgo individual, evolución conductual, tasa de reporte.
Ventajas Técnicas	Alta personalización, refuerzo positivo, enfoque continuo.
Limitaciones	Costo elevado y enfoque fuerte en gamificación.

Destaca por su enfoque conductual basado en ciencia del comportamiento. Sin embargo, su dependencia de gamificación puede no adaptarse a culturas corporativas formales.

Proofpoint

Modelo Tecnológico	Integrado con ecosistema avanzado de protección de correo.
Tipo de Simulación	Campañas automatizadas y dirigidas por perfil de riesgo.
Integraciones	SIEM, DLP, correo empresarial, SOC.
Métricas	Threat intelligence, scoring de vulnerabilidad.
Ventajas Técnicas	Alta integración y análisis de amenazas reales.
Limitaciones	Complejidad operativa y curva de aprendizaje alta.

Es robusto para entornos empresariales complejos, pero puede resultar sobredimensionado para organizaciones pequeñas.

KnowBe4

Modelo Tecnológico	Biblioteca extensa de contenido y simulación automatizada.
Tipo de Simulación	Plantillas prediseñadas y personalizables.
Integraciones	Active Directory, Microsoft 365.
Métricas	Phish-prone percentage, reportes ejecutivos.
Ventajas Técnicas	Gran variedad de recursos educativos.
Limitaciones	Menor personalización adaptativa comparado con IA avanzada.

Es una de las plataformas más consolidadas del mercado; su fortaleza radica en contenido masivo, aunque su enfoque puede percibirse estandarizado.

Cofense

Modelo Tecnológico	Orientado a respuesta colaborativa ante incidentes.
Tipo de Simulación	Campañas vinculadas a reporte activo del usuario.
Integraciones	SOC, herramientas de respuesta a incidentes.
Métricas	Tiempo de reporte, análisis de comportamiento.
Ventajas Técnicas	Fuerte alineación con equipos de seguridad.
Limitaciones	Menor enfoque en experiencia formativa.

Aporta valor en madurez operativa, aunque prioriza respuesta técnica sobre pedagogía.

Phished

Modelo Tecnológico	IA avanzada para simulaciones hiperpersonalizadas.
Tipo de Simulación	Emails adaptativos según comportamiento previo.
Integraciones	Microsoft 365, Google Workspace.
Métricas	Nivel de resiliencia individual.
Ventajas Técnicas	Alta sofisticación técnica.
Limitaciones	Menor presencia global.
Enfoque Ético	Aprendizaje progresivo individual.

Su enfoque adaptativo es altamente realista, pero requiere buena gobernanza de datos.

Ninjio

Modelo Tecnológico	Microaprendizaje audiovisual tipo storytelling.
Tipo de Simulación	Complementa simulación con formación narrativa.
Integraciones	Plataformas LMS.
Métricas	Participación y finalización de módulos.
Ventajas Técnicas	Alto engagement.
Limitaciones	Menor profundidad en análisis técnico de phishing.
Enfoque Ético	Educativo narrativo.

Excelente para cultura organizacional, aunque no sustituye motores técnicos avanzados.

Mimecast

Modelo Tecnológico	Integrado a solución de correo seguro empresarial.
Tipo de Simulación	Campañas integradas a políticas de correo.
Integraciones	Infraestructura propia de seguridad.
Métricas	Riesgo organizacional agregado.
Ventajas Técnicas	Ecosistema unificado.
Limitaciones	Dependencia del entorno Mimecast.
Enfoque Ético	Políticas corporativas definidas.

Ideal para clientes del ecosistema, menos flexible fuera de él.

Infosec IQ

Modelo Tecnológico	Capacitación modular con simulaciones estándar.
Tipo de Simulación	Plantillas configurables.

Integraciones	LMS, Active Directory.
Métricas	Seguimiento por usuario y área.
Ventajas Técnicas	Flexibilidad temática.
Limitaciones	Menor sofisticación adaptativa.
Enfoque Ético	Capacitación estructurada.

Adecuado para cumplimiento normativo, pero menos innovador tecnológicamente.

Tabla Comparativa

Plataforma	IA Adaptativa	Integración SIEM/SOC	Personalización	Escalabilidad	Enfoque Ético	Complejidad Técnica
Hoxhunt	Motor de aprendizaje conductual que ajusta dinámicamente los escenarios según el comportamiento individual en tiempo real.	Integración vía API con Microsoft 365 y exportación estructurada de métricas para correlación externa en SIEM.	Generación de campañas únicas basadas en historial conductual del usuario.	Arquitectura cloud diseñada para despliegue en organizaciones medianas y grandes.	Modelo explícitamente no punitivo enfocado en mejora continua y cultura positiva.	Requiere alineación estratégica inicial y gestión cultural del cambio.
Proofpoint	Personalización basada en inteligencia global de amenazas con segmentación por perfil de riesgo organizacional.	Integración nativa con SIEM, DLP y flujos operativos de SOC empresariales.	Campañas dirigidas por análisis de vulnerabilidad y riesgo por departamento.	Arquitectura empresarial robusta orientada a grandes corporativas multinacionales.	Cumplimiento estructurado bajo políticas formales y marcos regulatorios.	Alta complejidad por integración profunda en ecosistemas empresariales.
KnowBe4	Automatización basada en segmentación predefinida sin adaptación conductual dinámica avanzada.	Compatibilidad con Active Directory y exportación de reportes para análisis en herramientas externas.	Amplia biblioteca de plantillas con personalización manual configurable.	Modelo SaaS escalable con gestión centralizada multi-sede.	Orientado a cultura preventiva y cumplimiento normativo.	Configuración intermedia con curva de aprendizaje moderada.
Cofense	Enfoque predominantemente reactivo centrado en reporte de usuario más que en predicción adaptativa automatizada.	Alineación directa con equipos SOC para facilitar respuesta a incidentes reportados.	Segmentación por áreas funcionales vinculada a procesos operativos.	Orientado a organizaciones con madurez intermedia en seguridad operativa.	Fomenta cultura de reporte activo y colaboración interna.	Implementación alineada a procesos formales de respuesta a incidentes.
Phished	Algoritmos de personalización dinámica que ajustan campañas según historial previo del usuario.	Integraciones estándar con Microsoft 365 y Google Workspace para monitoreo continuo.	Simulación hiperrealista basada en patrones históricos de interacción.	Modelo SaaS adaptable a diferentes tamaños organizacionales.	Aprendizaje progresivo individual enfocado en mejora continua.	Dependencia de calidad y volumen de datos históricos para máxima eficacia.
Ninjio	No incorpora IA adaptativa; el	Integración principalmente	Personalización centrada en	Escalable en distribución	Concienciación cultural	Baja complejidad

	enfoque se centra en formación audiovisual estructurada.	con plataformas LMS, limitada en entornos SOC.	narrativa cultural y storytelling educativo.	masiva de contenido formativo digital.	mediante narrativa educativa.	técnica al centrarse en capacitación multimedia.
Mimecast	Personalización vinculada a análisis agregado de riesgo dentro de su ecosistema de seguridad de correo.	Integración profunda dentro de su infraestructura propietaria de protección de correo.	Configuración alineada a políticas internas y controles de seguridad corporativa.	Alta escalabilidad dentro de su arquitectura propietaria.	Alineado a políticas internas de seguridad corporativa.	Alta complejidad debido a dependencia del ecosistema Mimecast.
Infosec IQ	Segmentación configurable mediante reglas predefinidas sin aprendizaje autónomo avanzado.	Integración básica mediante exportación de métricas y compatibilidad con LMS.	Rutas formativas configurables según rol organizacional.	Implementación progresiva bajo modelo SaaS flexible.	Formación estructurada orientada a concienciación formal.	Administración centralizada con complejidad técnica moderada.

Conclusión

El análisis comparativo permite observar que las plataformas con mayor integración empresarial y capacidades de inteligencia adaptativa resultan especialmente valiosas en organizaciones con alta madurez en ciberseguridad, ya que permiten correlacionar resultados de simulación con eventos reales, fortalecer la gestión de riesgos y apoyar estrategias como Zero Trust. Sin embargo, la elección adecuada no depende únicamente del nivel tecnológico, sino también del tamaño de la organización, el presupuesto, la infraestructura existente y la cultura interna. Una solución altamente compleja puede ser innecesaria en entornos pequeños, mientras que una herramienta centrada solo en formación podría ser insuficiente en empresas con operaciones críticas.

Por ejemplo, en una institución financiera que sufre intentos constantes de phishing dirigido (phishing), una plataforma con integración al SOC permitiría detectar patrones de comportamiento, correlacionarlos con alertas reales y ajustar automáticamente la capacitación del personal más expuesto. En contraste, una empresa mediana podría beneficiarse más de un modelo formativo con enfoque cultural que fortalezca la conciencia sin requerir una infraestructura técnica avanzada.

Desde el punto de vista ético, las soluciones que promueven aprendizaje continuo y cultura de reporte generan mayor sostenibilidad y confianza organizacional. En última instancia, la efectividad no radica solo en la sofisticación tecnológica, sino en el equilibrio entre integración técnica, contexto organizacional y responsabilidad institucional.

Referencias

National Institute of Standards and Technology. (2018). *Framework for improving critical infrastructure cybersecurity (Version 1.1)*. U.S. Department of Commerce. https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.04162018.pdf

International Organization for Standardization. (2022). *ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection — Information security management systems — Requirements*. https://www.iso.org/standard/27001

European Union Agency for Cybersecurity. (2020). *Cybersecurity culture guidelines: Behavioural aspects of cybersecurity*. https://www.enisa.europa.eu/publications/cybersecurity-culture-guidelines-behavioural-aspects-of-cybersecurity